

Project Security & Features Report

Shree Ramchandra Temple (Ram Mandir) — Website and Administration Portal

How the security of the software is maintained, and what the software does

Prepared by	ZeroInfinity Infotech — Administration
Prepared for	Ram Mandir (Shree Ramchandra Temple) administration
Verified by	Sujan Subedi, Founder, ZeroInfinity Infotech
Report date	5 October 2026
Version	1.0
Classification	Confidential — for the temple administration only

1. Summary for management

This report explains, in plain language, what the temple's website and administration portal does, and how the software is protected and kept secure. It is written for the temple administration, not for programmers.

Overall result

The software is built on a solid security foundation. A full security audit was carried out on 5 October 2026: the server code, the website code and the configuration files were reviewed from three directions, the weak points that were found were tested against a throw-away copy of the system (never against the live data), they were fixed, and the same tests were run again to prove that each fix works. The main protections are in place. A small number of low-risk items were deliberately left open (section 9), and a short list depends on the settings of the live server and on the temple's own accounts and keys (section 6).

How to read the status labels in this report

- **In place** — built into the version of the software prepared by ZeroInfinity Infotech and checked in the code and by automated tests. It protects the live website once that version is deployed (see the first recommendation in section 6).
- **Recommended** — to be switched on or done at go-live, or by the temple administration (settings, accounts, hosting). The software cannot do these by itself.

Security at a glance

Area	What it means for the temple	Status
Sign-in	Passwords are stored in a scrambled form that cannot be read back. People can also sign in with Google or an e-mailed one-time code. Guessing is slowed down and blocked.	In place
Who can do what	Visitors, administrators and one super administrator. Each administrator only gets the areas the super administrator allows, and this is checked on the server, not just hidden on the screen.	In place
Data entered into the site	Everything typed into forms is cleaned before it is used. Unsafe links are refused. Visitors can upload pictures only.	In place
Donations and bookings	Every payment is confirmed directly with eSewa, Khalti or ConnectIPS by the server. Nothing is trusted just because the browser says so.	In place
E-mail and newsletter	Nobody receives the newsletter without confirming their address. Every message has an unsubscribe link. Daily sending limits protect the mail account.	In place
Visitor privacy	Phone numbers, booking references and secret links are kept out of logs and analytics.	In place
Audit trail	Administrator actions are recorded (who, what, when) and can be reviewed by the super administrator.	In place
Backup and restore	A backup and restore tool is built into the administration portal. Automatic scheduled copies kept in a separate place are still to be set up.	Recommended

Area	What it means for the temple	Status
Live-server settings and keys	Strong, separate secret keys for the live server, two-step sign-in for administrators, and the browser protection headers on the website host.	Recommended

2. About the software

The software is the official website of Shree Ramchandra Temple (Ram Mandir) together with the administration portal that temple staff use to manage the website, bookings, donations and messages from devotees.

- **Users:** devotees and visitors (reading the website needs no account), temple administrators with limited areas, and a super administrator.
- **Languages:** English, Nepali, Hindi, Chinese and Tamil, on phones and computers.
- **Information handled:** names, e-mail addresses and phone numbers of people who book, donate, write to the temple or subscribe; donation and booking records; temple content such as events, photographs and articles.
- **Where the data lives:** the database is a managed cloud database (MongoDB Atlas); photographs and videos are kept with Cloudinary; the software is designed to run on the Render hosting platform; e-mail is sent through the temple's mail account; payments go through eSewa, Khalti and ConnectIPS.

Because these services are run by other companies, their own security also applies. This report covers the temple software and the way it is configured.

3. What the software does (basic features)

3.1 The public website

Feature	What it does
Home page	Temple timings, daily aarti, daily quote, upcoming events, a notice pop-up, and Live Darshan (the live video from the temple's Facebook page, or a saved video link).
About, History and Team	The story of the temple, its history, and the committee and staff.
Events	Upcoming and past events with photographs. Visitors can mark interest, share an event and send a puja booking request.
Puja booking	Book ceremonies and services, receive a booking reference, and see the booking again under "My bookings".
Donations	Donate through eSewa, Khalti or ConnectIPS, or by bank account or QR code. A receipt after each donation, and a list of the person's own bookings and donations on their Profile page.
Gallery	Photographs in categories, each with a title and description. Temple videos are shown on the home page.
Blogs	Articles and notices published by the temple.

Feature	What it does
Calendar (Patro)	Nepali calendar with festivals, tithi, Ekadashi, Purnima, Aunsi and sunrise and sunset. Dates can be added to a phone calendar, and a signed-in visitor can ask for an e-mail reminder before a festival.
Tools	Date Converter (Nepali and English dates), Unicode / Preeti Converter, Currency Exchange, and Time & Weather for Kathmandu.
Contact	A message form with a spam and rude-language filter, map and directions, frequently asked questions, and visitor reviews that appear only after an administrator approves them.
Stay updated (newsletter)	Visitors subscribe with their e-mail address and choose Events, Festival wishes and News. They confirm by e-mail first and can unsubscribe at any time. The temple sends event announcements, new blog posts and festival greetings on the day.
Chat assistant	Answers common questions about timings, events, donations and bookings.
Language, phone and search	Five languages, phone-friendly pages, Privacy and Terms pages, and page titles and descriptions that help search engines.

3.2 Visitor accounts

- Sign in with Google, with an e-mailed one-time code, or with an e-mail address and password.
- A profile page, saved login on the same device, and password reset by e-mail code.
- An account is needed for donations and for the personal lists on the Profile page and “My bookings”. Browsing the website and sending a contact message do not need one.

3.3 The administration portal

Section	What administrators can do
Overview	A summary of recent activity.
Content	Home settings, About, History, Team, Events, Daily Aarti and Info, Blogs, Gallery, and the Notice pop-up.
Management	Puja bookings and the price list, donations (review and approve), contact messages, subscribers and mailings, visitor reviews, visitor analytics, backup and restore, and cloud storage.
Accounts	Users, administrators and their access areas (super administrator), the audit log, and “My account”.
Settings	Hero banner, daily quote, temple timings, logo, footer, social links and the Facebook live video.

3.4 What only the super administrator can do

- Create, suspend and remove administrators, and choose which areas each administrator may use.
- Change the donation switches and the donation account details.

- Restore or delete backups, and use the database tools (which only show this website's own data and never show passwords).

4. How the security of the software is maintained

4.1 Safe sign-in and passwords

- **Passwords are never kept as typed.** They are stored in a scrambled form (bcrypt) that cannot be turned back into the password.
- **One password rule everywhere.** At least 8 characters, no common passwords such as "123456", no simple repeats or runs, and the password may not contain the person's e-mail name.
- **Google sign-in is checked with Google itself.** The e-mail one-time code is 6 digits, valid for 10 minutes, usable once, with a limit on wrong guesses.
- **No hints for attackers.** A wrong password and an unknown e-mail address give the same answer at the same speed. Failed attempts are counted per account and per address, and repeated failures pause sign-in.
- **Password reset is hardened.** A 6-digit code, five guesses per code, a limited number of codes per hour, and "forgot password" answers the same whether or not the e-mail has an account.
- **Sessions can be ended.** A login lasts 30 days and renews while the person keeps visiting (the temple asked for saved logins). An administrator can suspend an account, and changing a password signs the person out on their other devices.
- **The super administrator account is created once.** The password in the settings file is never applied again, so a password changed inside the portal cannot be silently undone.

4.2 Who can do what

- **Three levels:** visitor, administrator, super administrator.
- **Access areas.** Administrators are given only the areas they need (content, bookings, donations, contact messages, users, analytics, system). Every request is checked on the server. This was tested by calling all 256 server routes as an anonymous visitor and as an ordinary user: nobody could change anything.
- **New administrators start with no powers.** An administrator on a temporary password cannot use any staff function until they choose their own password.
- **Sensitive actions are for the super administrator only:** donation switches, donation account, restoring or deleting backups.

4.3 Protection of what people type and click

- **Hidden database commands are stripped.** Text such as database operators typed into a form is removed before it reaches the database, and every search built from typed text is made safe.
- **Pages show text safely.** The website never inserts typed text as raw HTML. Links saved by administrators (map, footer buttons, social links, live video, payment screenshot) are refused if they could run a script. This was proved with deliberately poisoned data in a real browser.
- **E-mails are safe.** Everything a visitor typed is made harmless before it is placed into an e-mail, and each message goes to exactly one recipient.
- **Size limits.** Requests and uploads have size limits so that very large requests cannot slow the site down.

4.4 Files and uploads

- Visitors can upload pictures only: a profile photo up to 5 MB and a payment screenshot up to 10 MB, with an hourly limit. No video, SVG or web-page files are accepted from visitors.
- Administrators can upload photographs and videos up to 50 MB.
- Files are stored with Cloudinary, not on the web server's disk.

4.5 Donations and payments

- The server confirms every payment with eSewa, Khalti or ConnectIPS itself (signature, amount, owner and pending state). Nothing is trusted from the browser.
- Amounts must be real numbers within a sensible range. A payment is counted once even if it is confirmed twice at the same moment.
- The test-payment hints used during development are hidden on the live website, and error messages never reveal payment settings.

4.6 E-mail and the newsletter

- **Confirmation first (double opt-in).** Subscribing only sends a confirmation e-mail. The person is added after pressing the confirm button. The link is valid for 7 days, and addresses that never confirm are removed after 30 days.
- **Easy to leave.** Every message carries the person's own unsubscribe link, and the mail program's one-click unsubscribe works too.
- **No account guessing.** The subscribe form gives the same answer for a known and an unknown address, and a hidden trap field catches simple robots.
- **Limits that protect the mail account.** A limit per address and per hour, a daily ceiling on confirmation e-mails, and a daily ceiling on newsletter e-mails (300 by default, below the mail provider's own limit). A large mailing simply carries on the next day.
- **Sensible behaviour.** Nobody is mailed twice; someone who unsubscribes during a mailing is not mailed afterwards; a mailing can be stopped at once; sending stops by itself if the mail server keeps refusing; a festival greeting is sent only on its own day.
- **Calendar reminders** go only to the e-mail address of the signed-in account, each with a link to stop the reminder.

4.7 Protection against abuse and overload

- An overall ceiling per visitor address, and stricter limits on sign-in, sign-up, password reset, contact messages, reviews, bookings, uploads, subscribing and reminders. The server learns the visitor's real address behind the hosting platform, so one person cannot use up everybody's allowance.
- The contact form filters rude words (in several languages), links, spam and keyboard-mash text. Visitor reviews wait for an administrator to approve them.
- One failed background task can no longer stop the whole website.

4.8 Visitor privacy

- Logs record the page, not the full address (which could contain a phone number or a booking reference). Sign-in logs contain no e-mail addresses.
- The secret part of a password-reset link is never stored in the visitor statistics, and visitor addresses are no longer sent to an outside lookup site in plain text.

- Visitors see generic error messages; technical detail stays on the server. The super administrator's database screens never show password hashes or reset codes.

4.9 Audit trail and warnings

- Administrator actions (for example changing content, approving a donation, sending a mailing, changing a setting) are recorded with who and when, and can be reviewed in the Audit log.
- New bookings, donations and subscribers create notifications for the administrators.
- When the server starts it prints a clear warning if a live setting is unsafe (a weak signing key, a placeholder web address, a payment gateway still in test mode, a missing API address). The website build refuses to run while placeholder addresses remain.

4.10 Secrets and configuration

- No passwords or keys are written in the program code. They are kept in a private settings file that is excluded from the code repository and from the server image; an example file without secrets is provided.
- The server image runs as an ordinary user on a current version of Node.js.
- Software libraries with known weaknesses were updated during the audit, and the tests are repeated after every change.

4.11 Browser protection headers

Where	What is set	Status
The server (API)	No content-type guessing, no framing, HTTPS-only pinning, no referrer, a strict content policy and no software name or version in responses.	In place
The website host	A tested content-security policy is delivered ready to use in "report-only" mode, which cannot break the site. After a week without complaints it is switched to enforcing.	Recommended

4.12 Testing and independent review

- **The audit of 5 October 2026.** Three independent reviews (server code, website code, secrets and deployment files) produced 51 distinct findings. 32 were fixed completely in the code, 8 need action by the temple (keys, accounts, hosting) and also received a code safeguard, and 11 are low-risk and were partly fixed or accepted.
- **A second independent review of the fixes themselves** found 13 problems in the first version of the fixes. 12 were fixed and re-tested and 1 was accepted.
- **Attack simulations on a throw-away copy** (never the live data): forged logins, injection, access to other people's data, cross-site calls, oversized requests, upload tricks and rate limits. 132 automated checks pass (112 on the server, 9 on uploads and 11 in a real browser).
- **New features are tested the same way.** The newsletter has about 160 further automated checks (server, background sending and a real browser), its server code was reviewed independently and the points raised were addressed, and the e-mail sign-in code and the access-area system have their own test suites.

5. Backup and recovery

A backup that sits in the same place as the system is not a real backup. This is what exists today and what is recommended.

Item	What it covers	Status
Backup and Restore in the portal	Administrators with the system area can create a backup of the site's content and records. Backup files are private and can be downloaded for 10 minutes only.	In place
Restore and delete	Only the super administrator can restore or delete a backup. A restore never overwrites user accounts.	In place
Scheduled automatic backups	A backup every night, kept in a different place from the live database. A paid MongoDB Atlas plan includes automatic cloud backups; the free plan does not, so please check the plan in use.	Recommended
Three copies, two kinds of storage, one elsewhere	Keep at least three copies, on two kinds of storage, with one outside the hosting account. Encrypt backup files before they leave the system.	Recommended
Restore test	Once every quarter, restore a recent backup into a test copy and check that it opens.	Recommended

Measure	Target	Meaning
Maximum data loss	Up to 24 hours	With a nightly backup, at most one day of changes could be lost.
Time to restore	A few hours	Time to prepare a new server or database and restore the latest backup.

6. What the temple administration should do (recommended)

These steps depend on the live server and on the temple's own accounts. They cannot be done from inside the software.

Recommendation	Detail	Status
Put the prepared version on the live server	The protections in this report are in the version of the software prepared by ZeroInfinity Infotech. Deploy that version (the server and the website) and restart the server, so that the live website is protected as well. Until then, the live website has only the protections of the version that is running on it.	Recommended

Recommendation	Detail	Status
Two-step sign-in for administrators	This is the biggest protection still to be added. Until it is available in the software, use a long unique password for every administrator, and protect the super administrator's e-mail account with two-step sign-in, because password-reset mail goes there.	Recommended
Strong, separate secret keys	Use a new login-signing key on the live server, different from any test computer. Change the database, cloud-storage, mail and payment passwords if they were ever kept in a file that was shared or zipped. Keep live and test databases separate.	Recommended
Finish the live settings	Set the real website address, the real API address, the number of proxies in front of the server, and the live payment keys and return addresses at the hosting dashboard (not in a file).	Recommended
Limit access to the database	Give the live website its own database name and user, allow connections only from the hosting platform where possible, and switch on the provider's alerts.	Recommended
Browser protection on the website	Apply the prepared header file at the website host and, after a week in report-only mode, enforce it.	Recommended
Test once after go-live	Send one real test e-mail, make one small donation with each gateway, and upload one photograph, to confirm that the live accounts work.	Recommended
Remove old copies of the project	Delete old zip files and old website builds that contain settings or keys, including copies in online storage.	Recommended
Optional: bot and attack filter	Put the website behind a filtering service such as Cloudflare's free plan.	Recommended

7. Routine maintenance

How often	Task
Daily	Automatic backup (once set up). Read the notifications for new bookings and donations.
Weekly	Review the audit log and any unusual sign-in activity. Approve or hide visitor reviews and read contact messages.
Monthly	Install software updates, run the security checks on the libraries and the automated tests, and remove accounts of people who have left.
Quarterly	Restore a backup into a test copy. Review each administrator's access areas.
Yearly	An independent penetration test by an outside specialist. Review how long visitor data is kept, and change the main secret keys.

8. Shared responsibilities

ZeroInfinity Infotech	Ram Mandir administration
Builds and maintains the security described in section 4.	Keeps passwords and the e-mail accounts used for the portal safe, with two-step sign-in where possible.
Provides updates and fixes when a security problem is found, and re-runs the automated tests after every change.	Decides who is an administrator and what each may do, and removes access promptly when someone leaves.
Advises on hosting settings, backups and monitoring, and helps with the steps in section 6.	Keeps the hosting, database, cloud-storage, mail and payment-gateway accounts under the temple's own control.
Investigates and corrects reported incidents.	Approves content, reviews and mailings; reports anything suspicious; decides how long visitor data is kept and handles privacy requests from devotees.

9. Scope and limits of this report

This report is based on a review of the project's source code, configuration templates and automated test records as at 5 October 2026, and on tests run against a throw-away copy of the system. It describes how the software is protected; it is not a certificate, and it is not the result of an outside penetration test. It covers the version of the temple software prepared and hardened by ZeroInfinity Infotech; an older copy of the website that is still running on a server does not have these protections until the prepared version is deployed.

Not yet tested with live accounts

- Real payments with the live eSewa, Khalti and ConnectIPS keys.
- Real uploads to the temple's own Cloudinary account.
- Real e-mail delivery through the temple's mail provider (a test message should be sent once after go-live; the mail provider limits the number of messages per day).
- The production website build with the browser protection headers on the live host.

Known limits that were accepted or left for a later update

- Logins last 30 days because the temple asked for saved logins; the mitigation is that sessions can be ended at any time.
- The public site-settings address also contains the donation account details that the Donate page shows anyway.
- A few low-risk items, such as public view counters that can be changed without signing in, are recorded for a later update.

10. Words used in this report

Word	Meaning
Two-step sign-in	Signing in with a password plus a second proof, such as a code from a phone app.

Word	Meaning
Rate limit	A cap on how many times something can be tried in a given time, to stop automatic guessing and flooding.
Double opt-in	A person is added to the newsletter only after they confirm from a message sent to their own inbox.
Audit log	A record of who did what and when in the administration portal.
Penetration test	A planned, authorised attack on the system by a security specialist, to find weaknesses before real attackers do.
Content-security policy	A rule sent to the browser that tells it which scripts and pictures a web page may load.

11. Verification and sign-off

This report was prepared by the ZeroInfinity Infotech administration from the project's source code, the security audit of 5 October 2026 and the automated test records, and is verified by the founder.

Role	Name	Signature	Date
Prepared by	ZeroInfinity Infotech — Administration		
Verified by	Sujan Subedi, Founder, ZeroInfinity Infotech		

Prepared by ZeroInfinity Infotech

zeroinfinitytechnologies.com